

MID-STATE TECHNICAL COLLEGE • IT PROGRAMS

Creating and Managing Security Policy Rules

Unit 6 • Information Security 2 (10-151-111)



Learning Outcomes

By the end of this unit, you will be able to:



Describe Security policy operation

Explain where the policy check happens, how rule types work, and what the default rules do.



Order rules for first-match evaluation

Place rules so the right one matches, and find and fix shadowed rules.



Configure a Security policy rule

Build a rule tab by tab and choose the right service setting and action.



Use objects, EDLs, and tags

Replace hard-coded values with reusable objects and block known-bad addresses.



Verify and maintain the rulebase

Prove rules work with hit counts, Test Policy Match, and the Traffic log.



LESSON 1

Security Policy Fundamentals

Where the Policy Check Happens

The Security policy check happens during session setup, after the firewall knows both zones:

Session setup step	What the firewall works out
Existing session?	If yes, skip setup and go straight to inspection and enforcement
Source zone	The zone of the ingress interface the packet arrived on
Forwarding lookup	The virtual router (or PBF) picks the egress interface
Destination zone	The zone of that egress interface, plus a destination NAT check
Security policy check	Match the session to one rule, then assign a session ID

Two details that matter later: the check uses pre-NAT IP addresses, and traffic to the out-of-band MGT port never touches the data plane, so policy does not apply to it.

What a Rule Can Match On

Basic criteria (required)

- **Source zone** — where the session starts
- **Destination zone** — where the session is headed
- Every rule needs both; zones are the backbone of the policy

Granular criteria (optional)

- **Address** and **user** — who is talking, by IP or by User-ID
- **Application** — what App-ID says the traffic really is
- **Service, URL category, HIP profile** — port, site category, endpoint posture

Every "any" is a choice: a criterion left at any allows everything in that column. Specific values mean fewer lookups and less unintended access.

Sessions and Flows

- Every packet is matched to a **session**, and every session to exactly **one rule**.
- A session holds one flow (multicast) or two (TCP): **c2s** client-to-server and **s2c** server-to-client.
- The **client** is whoever initiates; the **server** is whoever responds, even if it is a laptop.
- Write rules for the c2s direction only. Return s2c traffic in the same session is allowed automatically.

Rules are one-way

If connections must start from both sides, you need **two rules**. That is why the lab builds both `Block-to-Known-Bad-Addresses` and `Block-from-Known-Bad-Addresses`.

Three Rule Types

The rule type decides whether a rule covers traffic within zones, between zones, or both. Example: source zones ZoneA and ZoneB.

Type	Within a zone	Between zones	Notes
universal	Yes	Yes	The default and most common type
intrazone	Yes	No	No destination zone to choose
interzone	No	Yes	A→B and B→A, never inside A or B

In the Policies > Security table, the Type column shows which type each rule is. Hide it if you only ever use universal rules.

The Predefined Default Rules

intrazone-default

- **Allows** traffic within the same zone
- Hosts in Users_Net reach each other with no rule
- **Not logged** by default

interzone-default

- **Denies** traffic between different zones
- Anything not explicitly allowed is blocked
- **Not logged** by default

Don't add your own "deny all": placed above intrazone-default, it also blocks traffic inside every zone and breaks normal application traffic.

- **Revert** returns the rule to its predefined state.

 Add Delete Clone Override Revert Enable Disable **Move**

Policies > Security > select the rule > Override > Actions tab

LESSON 2

Rule Order and Shadowing



Top to Bottom, First Match Wins

- Rules are evaluated **top to bottom**. The first match is applied and **no further rules are evaluated**.
- **Specific before general**: narrow rules go above broad ones, or the broad rule catches the traffic first.
- **Blocks on top**: known-bad deny rules sit above every allow rule.
- Line numbers label positions, not rules. They do not move when a rule moves.

Combine when it's honest

Inside → Outside and Guest → Outside with the same app and action can become **one rule** with both source zones. Same access, fewer lookups, less to maintain.

Rule Shadowing

Commit Status

Operation Commit

Status Completed

Result Successful

Details Partial changes to commit: changes to configuration by administrators: admin
Changes to policy and objects configuration
Configuration committed successfully

Commit

Rule Shadow

1 item

RULE	TYPE	COUNT
Allow-All-Traffic	security-rule	1

1 item

SHADOWED RULE

Rule 'Allow-All-Traffic' shadows rule 'Users_to_Internet'.

- When traffic could match two rules, the earlier one **casts a shadow** and the later one never hits.
- Every commit reports it on the **Rule Shadow** tab of the Commit Status window.
- Fix it by editing or removing the broad rule. Reordering alone only swaps which rule is hidden.

Managing the Ruleset

- **Add**, **Clone**, **Delete**, and **Move** (or drag-and-drop) from the toolbar under the table.
- **Disable** keeps a rule without enforcing it. It shows in gray italics, which is handy for staging or troubleshooting.
- Each admin can show, hide, and reorder table columns. Customizing is per user.



SECURITY FOCUS

An "Allow-All-Traffic" rule near the top shadows every careful rule beneath it and allows any application from the zones it names.

Why it matters: One broad rule quietly undoes the segmentation you built last unit.

LESSON 3

Building a Rule, Tab by Tab



General Tab

- A unique, case-sensitive **name** and a **description** of the rule's purpose.
- **Rule Type**: universal by default; intrazone and interzone are the alternatives.
- **Tags** and **Group Rules By Tag** help you filter and organize.
- **Audit Comment** records why, when, and by whom. The **Audit Comment Archive** keeps the history.

Security Policy Rule

General

Source

Destination

Application

Service/URL Category

Name

Protected_Mail_Servers

Rule Type

universal (default)

Description

Policy designed to protect the Mail Servers on the Extranet.

Tags

Mail_Servers

Group Rules By Tag

Mail_Servers

Audit Comment

Mail Servers Policy created by admin-bob on 7/30

Audit Comment Archive

Policies > Security > Add

Source and Destination Tabs

Every field defaults to any. Leaving one empty is a decision too.

Field	Default	What you can add
Zone	any	One or more zones; multiple zones keep the rulebase short
Address	any	Addresses, ranges, groups, EDLs, or geographic regions
User (source)	any	pre-logon, known-user, unknown, or selected users and groups
Device	any	Defined IoT devices
Negate	off	Match every address except the ones listed

The lab rules only need zones. The block rules add EDLs in the address fields.

Application Tab

- Default is **any**. Add specific App-IDs instead.
- Check the **Depends On** pane: an app will not work unless its dependencies are allowed by some rule.
- Choosing a **parent** app includes all its child functions, including ones added in future content updates.
- On commit, the **App Dependency** tab lists missing dependencies per rule.

In this lab

Every rule uses **Any** for Application to keep the focus on zones. You will tighten rules to specific apps in the App-ID unit.

Service: any vs. application-default

The Service setting controls which ports an allowed application may use.

Setting	Behavior
any	The app may run on any port. Least restrictive and easiest to abuse.
application-default	Only the app's standard ports, e.g. web-browsing on TCP 80, ssl on TCP 443. The new-rule default.
select	A service object you choose. Only service-http (TCP 80, 8080) and service-https (TCP 443) come predefined.

Why it helps: an app on an unusual port won't match an application-default rule, and that is often a sign of evasion or malware.

Choosing an Action

Action	What happens
Allow	Permit the session. This is the default for a new rule.
Deny	Block using the application's own default deny behavior, often a TCP reset
Drop	Discard silently. Optionally send an ICMP Unreachable to the client.
Reset client	Send a TCP reset to the initiator
Reset server	Send a TCP reset to the responder
Reset both	Send a TCP reset to both ends

New rules default to Allow: building a block rule? Change the action on the Actions tab before you commit.

Logging and Schedules

Logging (Actions tab)

- Custom rules **log at session end** by default.
- Add **session start** only while troubleshooting; it adds load and disk use.
- Default rules log **nothing** until you override them.

Schedules

- Create one at `Objects > Schedules`, then pick it on the Actions tab.
- Daily, weekly, or non-recurring, in 24-hour time
- Sessions already **established** are not cut off when a rule kicks in.

The Usage tab, added after the rule is saved, shows creation and modification dates, hit activity, apps seen, and 30 days of bytes.

LESSON 4

Objects, EDLs, and Tags



Address Objects

Address ⓘ

Name: Bureau-121

Description: Address object for Bureau-121

Type: IP Netmask (dropdown menu open showing: IP Netmask, IP Range, IP Wildcard Mask, FQDN)

Value: 212.0.34.0/24 (Resolve button)

Enter an IP address or a network using the slash notation (Ex. 192.168.80.150 or 192.168.80.0/24). You can also enter an IPv6 address or an IPv6 address with its prefix (Ex. 2001:db8:123:1::1 or 2001:db8:123:1::/64)

Tags: (dropdown menu)

OK Cancel

- **IP Netmask:** a host or subnet, e.g. 192.168.50.0/24
- **IP Range:** 204.10.20.1–204.10.20.254
- **IP Wildcard Mask:** a pattern of addresses
- **FQDN:** resolved by DNS, up to 30 addresses

Objects > Addresses > Add

Define once, reuse everywhere: edit the object and every rule using it updates.

Static vs. Dynamic Address Groups

Static address group

- **You** manage the membership
- Holds address objects and other groups
- Every change needs a **commit**

Dynamic address group

- **Tags** manage the membership (e.g. *Quarantine*)
- Tags come from external software or firewall auto-tagging
- Membership changes need **no commit**

Objects > Address Groups > Add, then choose Static or Dynamic as the Type.

Blocking Known-Bad IP Addresses

Palo Alto Networks ships three built-in external dynamic lists (EDLs) that stay current with no commit:

Lab rule (top of the policy)	Source zone	Destination	Action
Block-to-Known-Bad-Addresses	Users_Net, Extranet	Internet · EDLs as dest. address	Deny
Block-from-Known-Bad-Addresses	Internet · EDLs as src. address	Users_Net, Extranet	Deny

- **Bulletproof IP addresses:** hosting providers that ignore abuse reports
- **High risk IP addresses** and **Known malicious IP addresses:** addresses tied to malicious activity

Two rules because rules are one-way: one blocks outbound to the lists, one blocks inbound from them.

Custom Services and Tags

Service objects

- `Objects > Services > Add`
- **TCP or UDP**, never both in one object
- Ports: single, range, or list, e.g. `8000-8010, 8443`

Tags

- `Objects > Tags > Add`, with a color and comment
- Filter the rulebase by tag. The **default rules** always stay visible.
- Multiple tags allowed; only the **first** tag's color shows

Enforce it: Device > Setup > Management can require tags and fail commits on rules with no tag or description.

LESSON 5

Verifying the Rulebase



Hit Count and the Usage Tab

- **Hit Count:** matches per rule, with **first-hit** and **last-hit** timestamps and apps seen.
- Generate traffic, click **Refresh**, and watch the right rule's count climb.
- **Reset Rule Hit Counter** for selected or all rules to test a change cleanly.
- The rule's **Usage** tab shows the same data plus 30 days of traffic.

Reset is permanent

Hit count data isn't kept anywhere else. Once reset, it is gone. Note the numbers first if you need them.

Test Policy Match

- Enter zones, source, destination, port, protocol, and optionally an app.
- The firewall shows which rule **would** match and its details. No traffic is sent.
- Use it before a commit to confirm ordering and catch shadowing early.

The screenshot displays the 'Test Security Policy Match' window, which is divided into three main sections: 'Test Configuration', 'Test Result', and 'Result Detail'.

Test Configuration: This section contains various input fields for defining a test scenario. The 'Select Test' dropdown is set to 'Security Policy Match'. Other fields include 'From' (Users_Net), 'To' (Internet), 'Source' (192.168.1.20), 'Source Port' ([1 - 65535]), 'Destination' (8.8.8.8), 'Destination Port' (80), 'Source User' (None), 'Protocol' (TCP), 'Application' (None), 'Uappid' ([10000000 - 4294967295]), 'Category' (None), 'Source OS' (None), 'Source Model' (None), 'Source Vendor' (None), 'Destination OS' (None), and 'Destination Model' (None). There are also checkboxes for 'show all potential match rules until first allow rule' and 'check hip mask'.

Test Result: This section shows the result of the test, with 'Allow-Internet-Access' selected.

Result Detail: This section provides a detailed view of the selected rule, organized into a table with 'NAME' and 'VALUE' columns.

NAME	VALUE
Name	Allow-Internet-Access
Index	6
From	Extranet
Source	Users_Net
Source Region	any
To	Internet
Destination	any
Destination Region	none
User	any
source-device	any
destination-device	any
Category	any
Application Service	0:any/any/any/app-default
Action	allow
ICMP Unreachable	no
Terminal	yes

Reading the Traffic Log

- Monitor > Logs > Traffic shows logged sessions.
- Type **end**: a normal allowed session.
- Type **drop**: blocked by an any-application rule, often before App-ID, so the app shows **not-applicable**.
- Type **deny**: blocked by a rule naming a specific app.

Detailed Log View

General		Source		Destination	
Session ID	127457	Source User		Destination User	
Action	allow	Source	192.168.1.20	Destination	172.217.9.14
Action Source	from-policy	Source DAG		Destination DAG	
Host ID		Country	192.168.0.0-192.168.255.255	Country	United States
Application	google-base	Port	55648	Port	80
Rule	Users_to_Internet	Zone	Users_Net	Zone	Internet
Rule UUID	e1a4b347-e1d4-45ba-8c97-5505e682e62f	Interface	ethernet1/2	Interface	ethernet1/1
Session End Reason	tcp-fin	NAT IP	203.0.113.20	NAT IP	172.217.9.14
Category	any	NAT Port	28419	NAT Port	80
Device SN		X-Forwarded-For IP	0.0.0.0		
IP Protocol	tcp				
Log Action					

Flags

Captive Portal ☐

PCAP	RECEIVE TIME	TYPE	APPLICAT...	ACTION	RULE	RULE UUID	BY...	SEVERI...	CATEG...	URL CATEG... LIST	VERDI...	URL	FILE NAME
	2020/07/14 19:42:47	end	google-base	allow	Users_t...	e1a4b...	912		any				

Click the magnifying glass on any entry for the Detailed Log View.

Filtering the Traffic Log

Both of these filters appear in the lab. Type them exactly, including the spaces inside the parentheses:

```
( addr.dst eq 8.8.8.8 ) and ( zone.src eq Users_Net )  
( addr.dst eq 8.8.8.8 ) and ( app eq ping )
```

- Click a value in any log entry to add it to the filter, then **Apply**.
- Use the column menu to hide columns you don't need, the same as in the policy table.

No entry ≠ no traffic: sessions that hit an unlogged default rule leave no trace. Log the defaults before you trust an empty result.

Keeping the Rulebase Clean

Tool	What it tells you
Highlight Unused Rules	Rules with no matches since the data plane last restarted
Policy Optimizer > Rule Usage	Filter rules by hit data and dates to find stale ones
Audit Comment Archive	Comment history, config logs, and a diff of rule versions
Global Find	Everywhere an IP, object, rule, or app appears in the config
View Rulebase as Groups	Rules grouped by tag, with rule order preserved

Global Find searches the candidate configuration, not logs or dynamic content.

Least Privilege in the Rulebase



SECURITY FOCUS

Every allow rule is attack surface you chose to keep. Broad rules (any application, any service, a catch-all allow near the top) turn a segmented network back into a flat one and shadow the careful rules below them.

Why it matters: Zero Trust only works if the rules between zones are specific, ordered, and logged.

- Name, describe, and tag every rule, and leave an audit comment on every change.
- Put known-bad blocks at the top, in **both directions**.
- Prefer specific apps with **application-default**, log the default rules, and cull unused rules on a schedule.

Hands-On Lab: Security Policy Rules

NETLAB+ · PAN-OS 11.0 Firewall Essentials Lab 5 · baseline edu-210-11.0a-05.xml

- Create and test `Users_to_Extranet`; examine and reset its hit count.
- Customize the policy table and Traffic log columns; filter the log.
- Log `interzone-default` at session end and confirm denied pings appear.
- Add the two known-bad block rules at the top (High-Level step 1.12).
- Add `Users_to_Internet` and `Extranet_to_Internet`, then prove pings hit the right rule.



Heads up: the Detailed Lab Steps skip the block rules. Do step 1.12 before section 2.7.

Why the Internet Ping Still Fails

- At the end of the lab, the ping to 8.8.8.8 **matches Users_to_Internet** and is allowed.
- No reply comes back: 192.168.1.20 is a private address that the internet can't route to.
- The Security policy is right. The **addressing** is the problem.

Next week: NAT

Source NAT will translate Users_Net traffic to 203.0.113.20. Remember: policy still matches on the **pre-NAT** addresses.

Key Takeaways



Zones are required; intrazone traffic is allowed and interzone traffic denied until you say otherwise.



Top-down, first match wins. Put specific rules and blocks on top, and watch for shadowing.



Prefer specific apps with application-default, and check the action before you commit.



Objects, EDLs, and tags make rules reusable, readable, and current.



Prove every rule with hit counts and the Traffic log, and log the default rules.

Unit 6 Homework

Always check Blackboard for assignments and due dates.

- **Unit 6 Lab:** NETLAB+ Lab 5, Creating and Managing Security Policy Rules
- **Unit 6 Quiz:** Security policy concepts, rule types, matching, actions, and objects



MID-STATE TECHNICAL COLLEGE · IT PROGRAMS

Questions?

Unit 6 · Creating and Managing Security Policy Rules